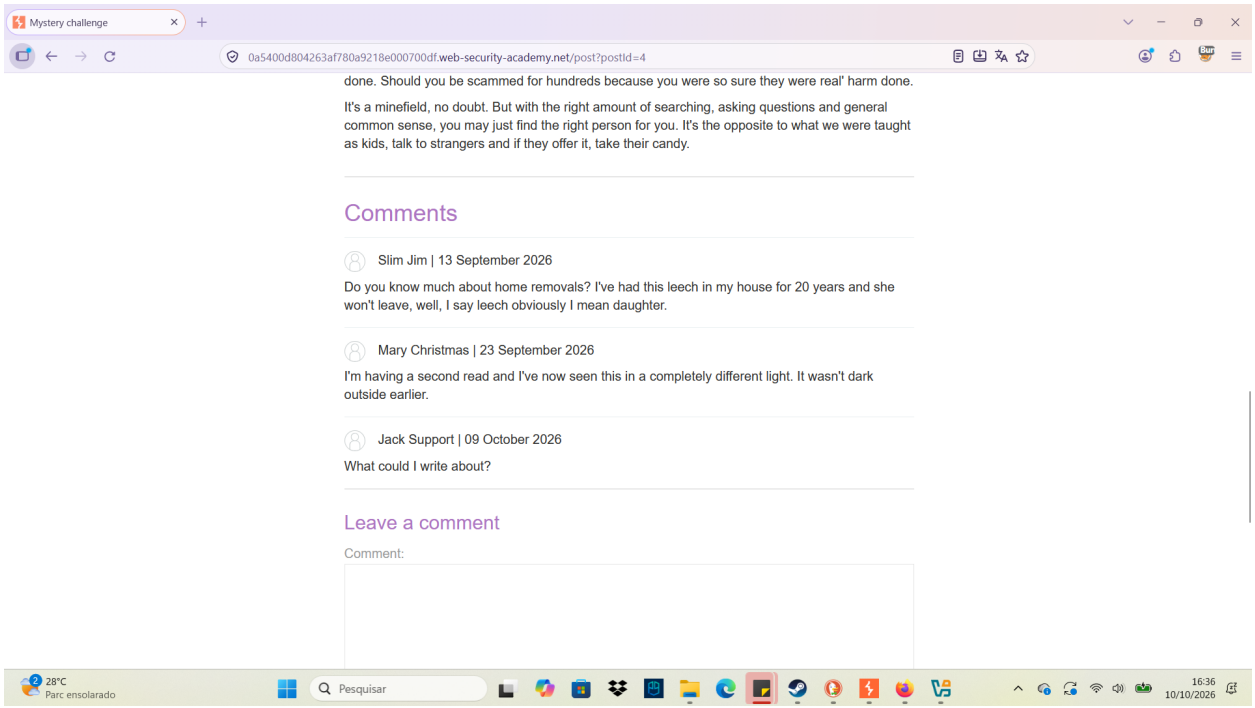
Lab: Web shell upload via path traversal

PortSwigger Web Security Academy — Registro de resolução

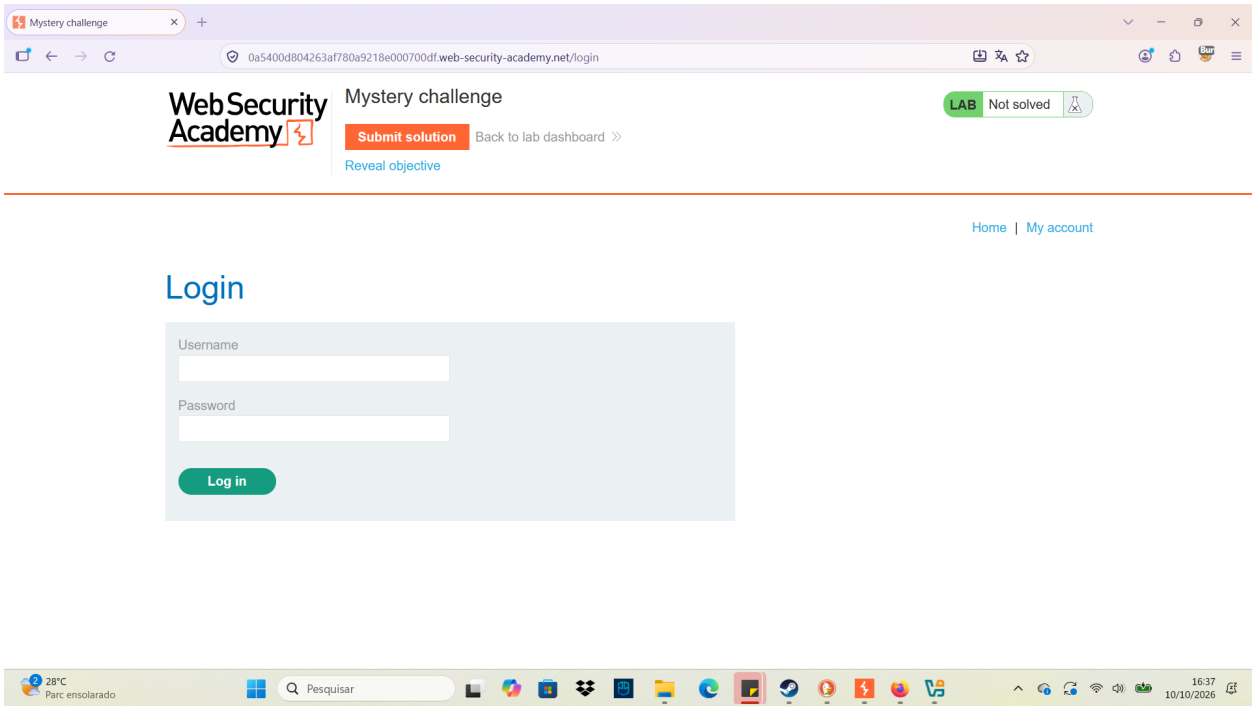
As imagens a seguir documentam, passo a passo, a exploração de uma função de upload de avatar vulnerável. A aplicação bloqueia a execução de arquivos dentro da pasta **/files/avatars/**, mas essa proteção pôde ser contornada por meio de uma segunda falha: um filtro de path traversal que reconhecia apenas a sequência literal **../** no nome do arquivo, sem decodificar o valor antes da checagem. Codificando a barra como **%2f** (resultando em **..%2fshell.php**), foi possível enganar o filtro na hora do upload e, apenas no momento em que o servidor resolveu o caminho real no disco, o traversal foi de fato interpretado — posicionando o arquivo um nível acima, em **/files/**, pasta onde o PHP é executado normalmente. Com a execução confirmada, a função **system()** mostrou-se bloqueada pelo ambiente, mas **shell_exec()** funcionou sem restrição, permitindo a execução de comandos arbitrários no servidor e, por fim, a leitura do arquivo **/home/carlos/secret**, submetido para concluir o laboratório.



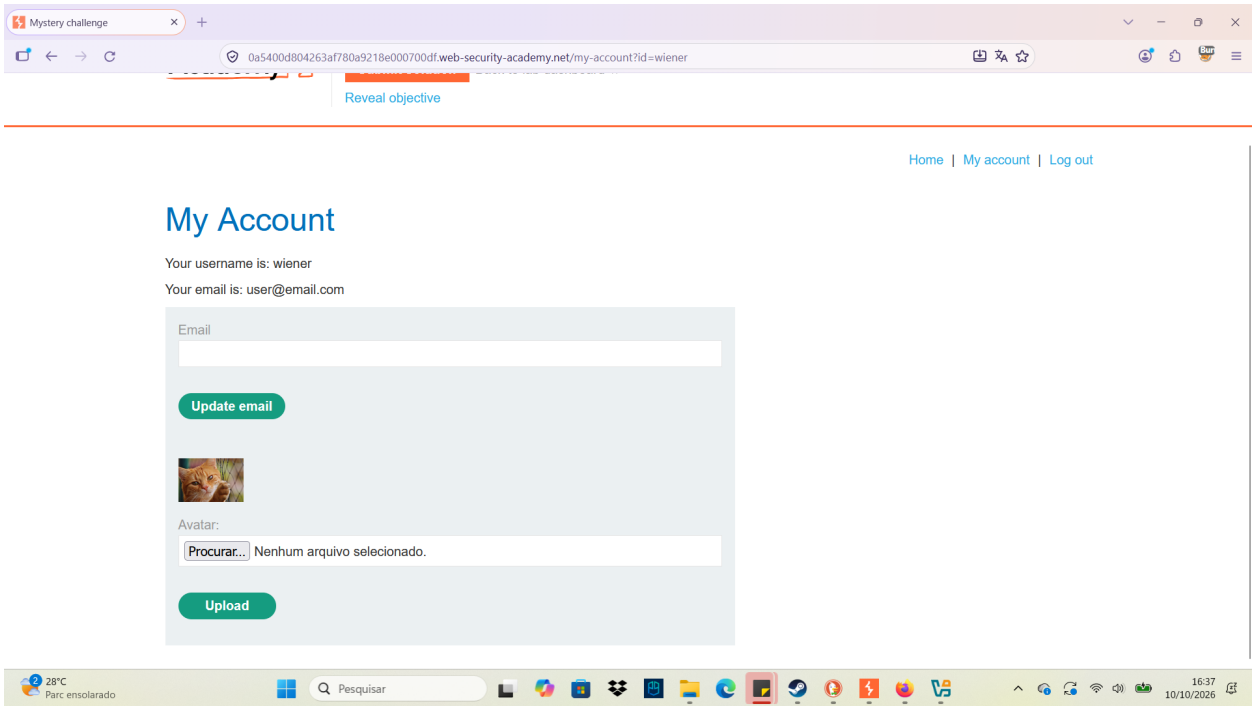
Aplicação-alvo: um blog fictício ("We like to blog") que compartilha a mesma base de código usada em vários laboratórios do Web Security Academy, incluindo a função de upload de avatar que será explorada.



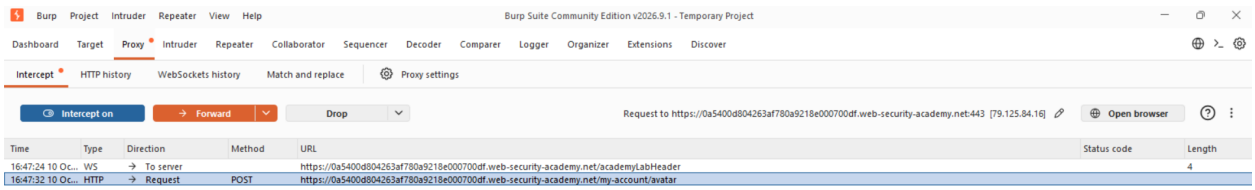
Página de um post do blog com seção de comentários — parte do conteúdo padrão da aplicação, sem relação direta com a vulnerabilidade, mas útil para mapear a estrutura do site antes do ataque.



Tela de login da aplicação. O acesso é feito com as credenciais de teste fornecidas pelo laboratório (**wiener:peter**).

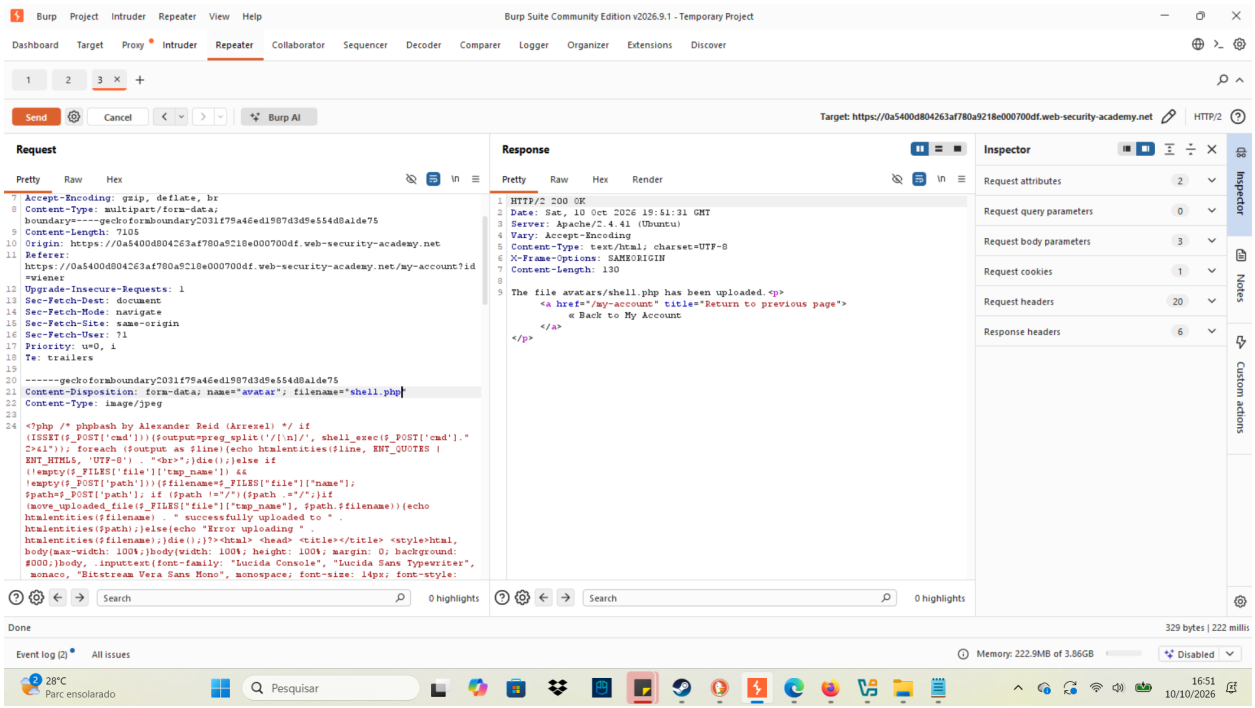


Página "My Account" já autenticado como **wiener**, mostrando o formulário de upload de avatar — o ponto de entrada da vulnerabilidade. Um avatar de gato já havia sido enviado em um teste anterior.

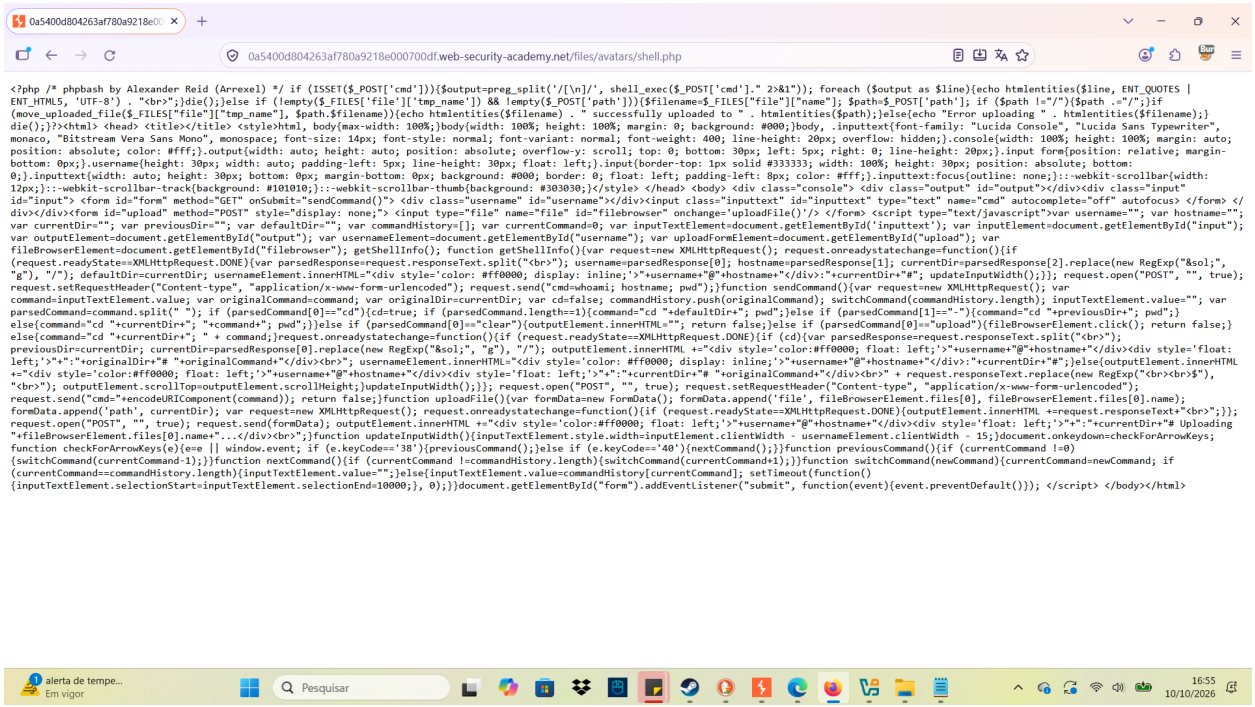




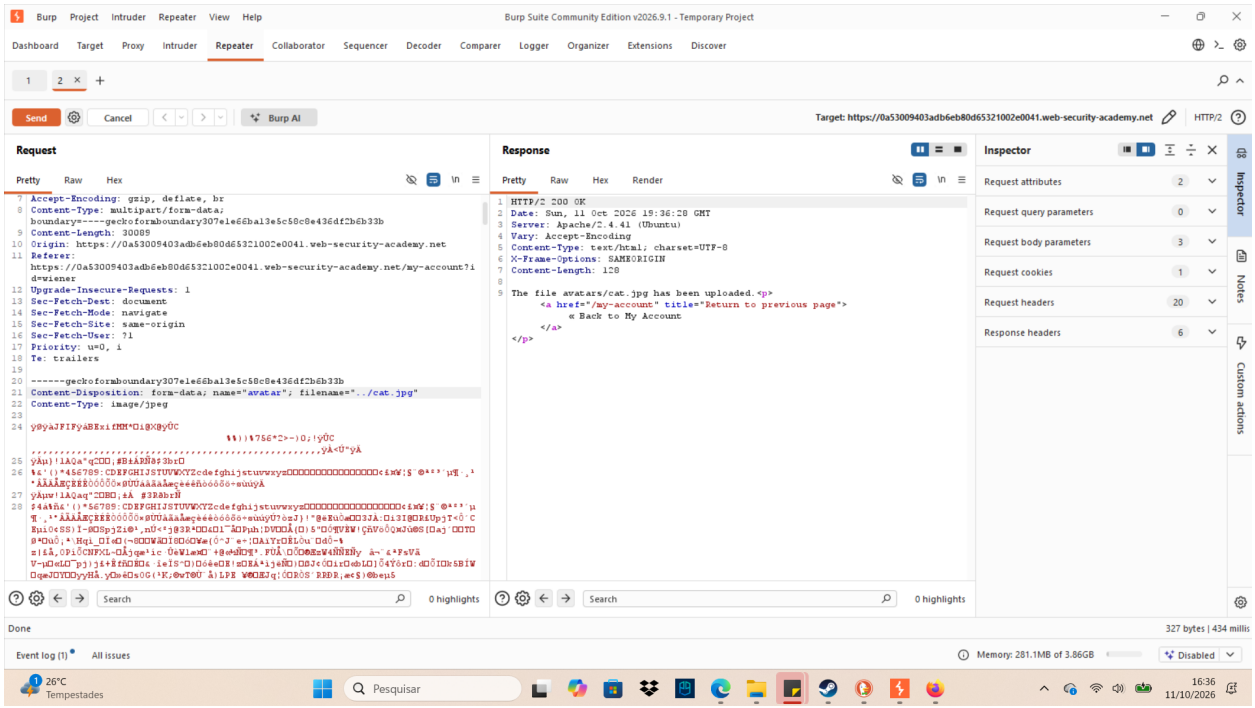
Requisição **POST /my-account/avatar** interceptada no Burp Suite durante um upload de teste com o arquivo **cat.jpg**, confirmando a estrutura multipart/form-data usada pela aplicação, incluindo os campos **avatar**, **user** e **csrf**.



Primeira tentativa de upload direto de uma web shell PHP completa (**shell.php**), sem qualquer manipulação de caminho. O servidor aceita o arquivo (**200 OK**, "The file avatars/shell.php has been uploaded"), mas isso ainda não garante que o PHP será executado.



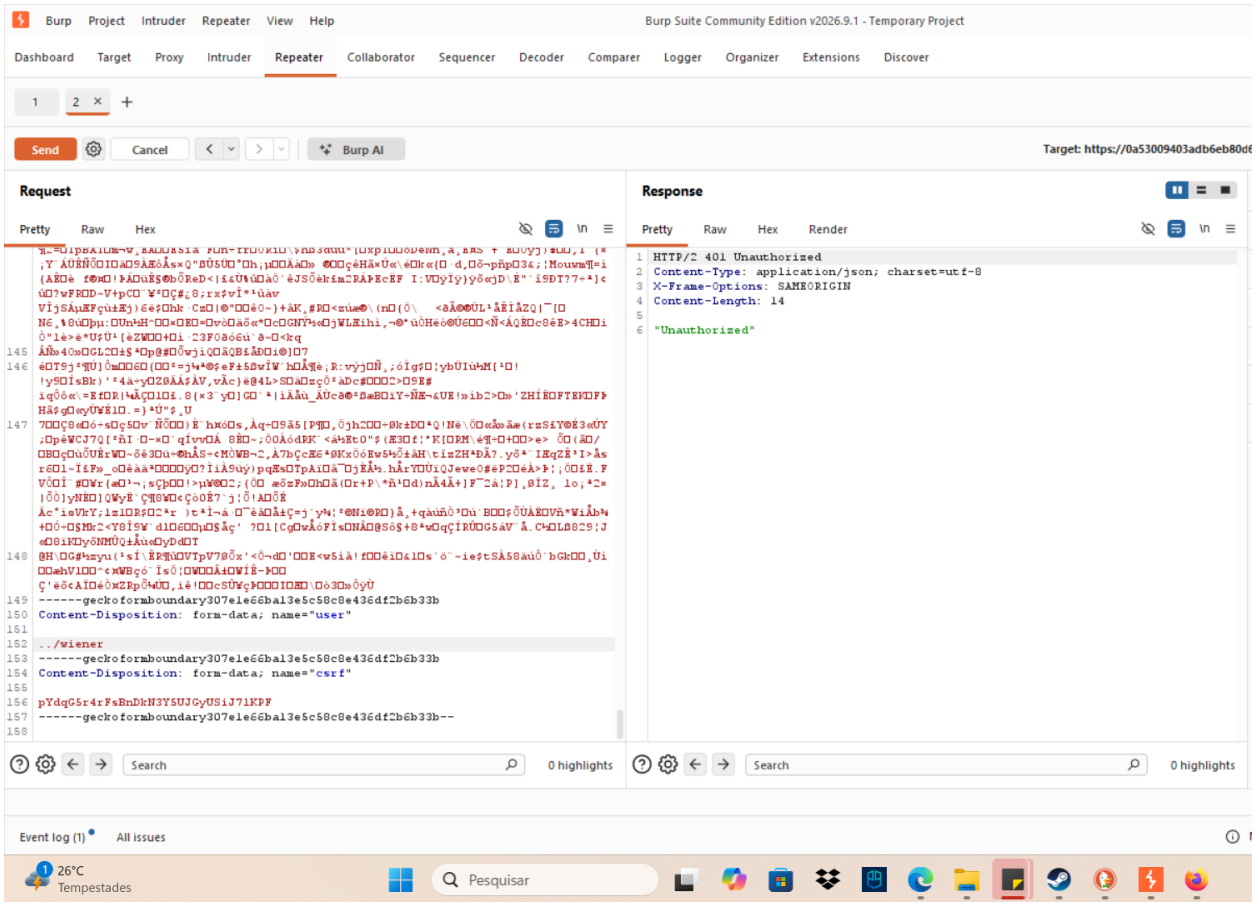
Ao acessar o arquivo enviado em **/files/avatars/shell.php**, o servidor devolve o código-fonte da shell como texto puro, em vez de executá-lo — confirmando que a pasta **avatars/** está configurada para impedir a execução de arquivos enviados pelo usuário.



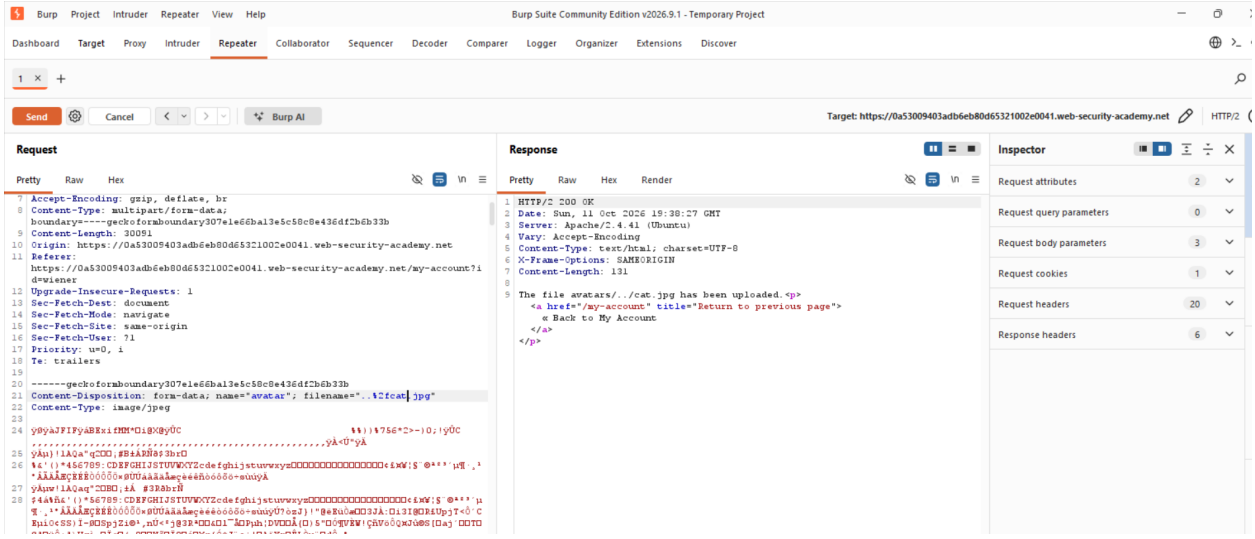
Primeira tentativa de path traversal, usando **../cat.jpg** como nome do arquivo. A mensagem de confirmação ainda mostra **avatars/cat.jpg**, indicando que a sequência **../** foi removida pelo filtro antes de o arquivo ser salvo.



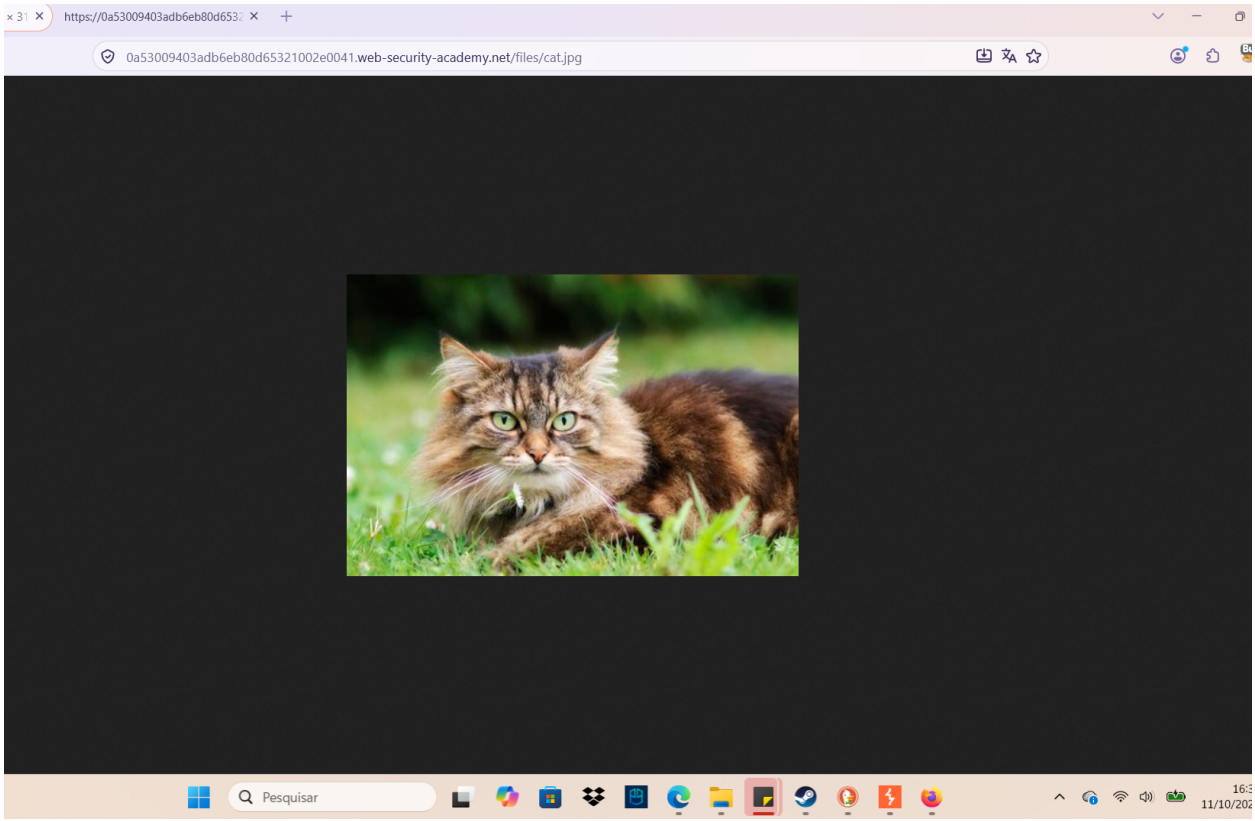
Retorno à página "My Account" do laboratório para preparar a próxima tentativa de upload, desta vez testando a manipulação de outros campos da requisição.



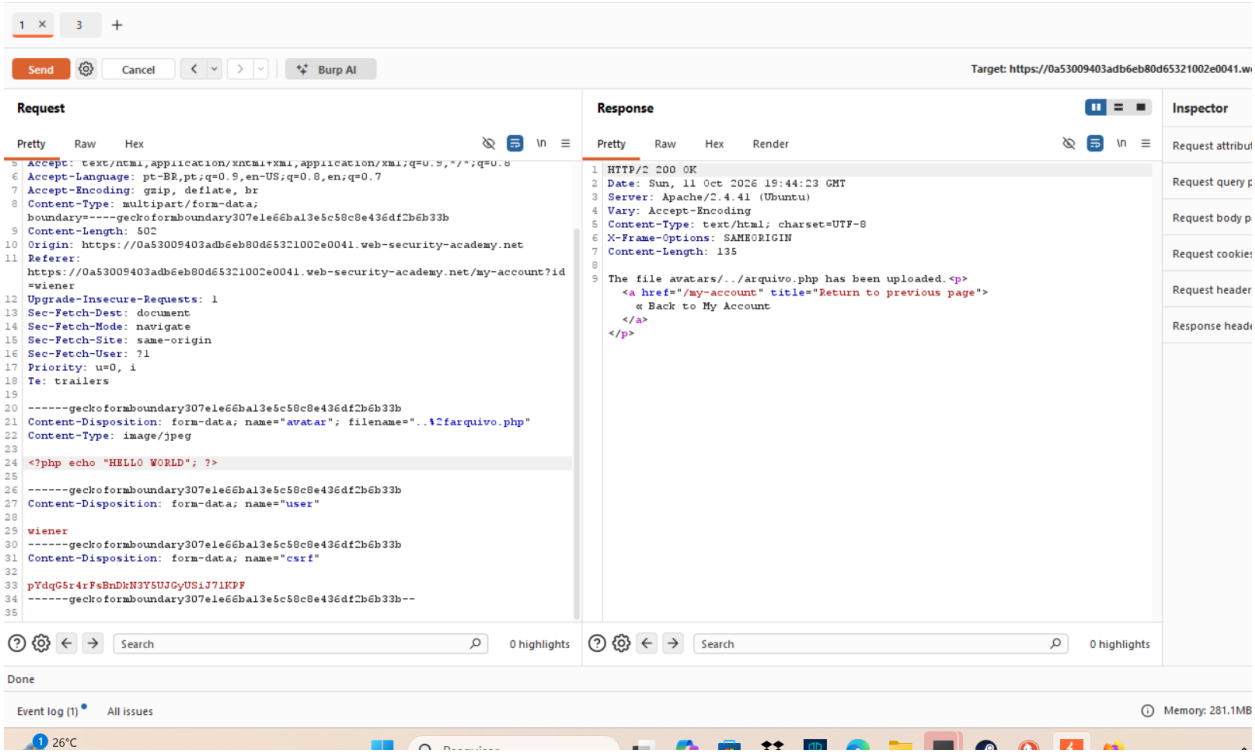
Tentativa de aplicar o path traversal no campo **user** (**../wiener**) em vez do nome do arquivo. O servidor responde **401 Unauthorized**, revelando que esse campo é usado para validar a identidade do usuário logado, não para compor o caminho do arquivo — um caminho sem saída.



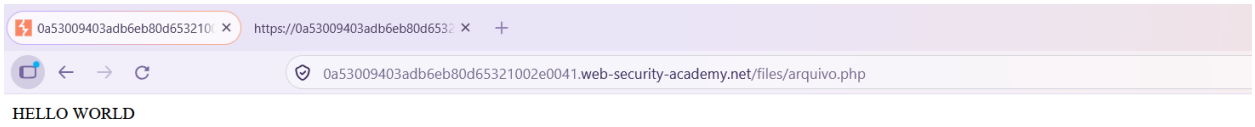
Bypass bem-sucedido do filtro: o nome do arquivo é enviado como **..%2fcat.jpg**, com a barra codificada em URL-encoding. O filtro, que buscava apenas a string literal **../**, não reconhece a sequência codificada, e a mensagem de confirmação passa a mostrar **avatars/../cat.jpg** — o traversal intacto.



Confirmação prática do bypass: acessando diretamente **/files/cat.jpg** — um nível acima da pasta **avatars/** — a imagem carrega normalmente, provando que o arquivo foi salvo fora do diretório restrito.

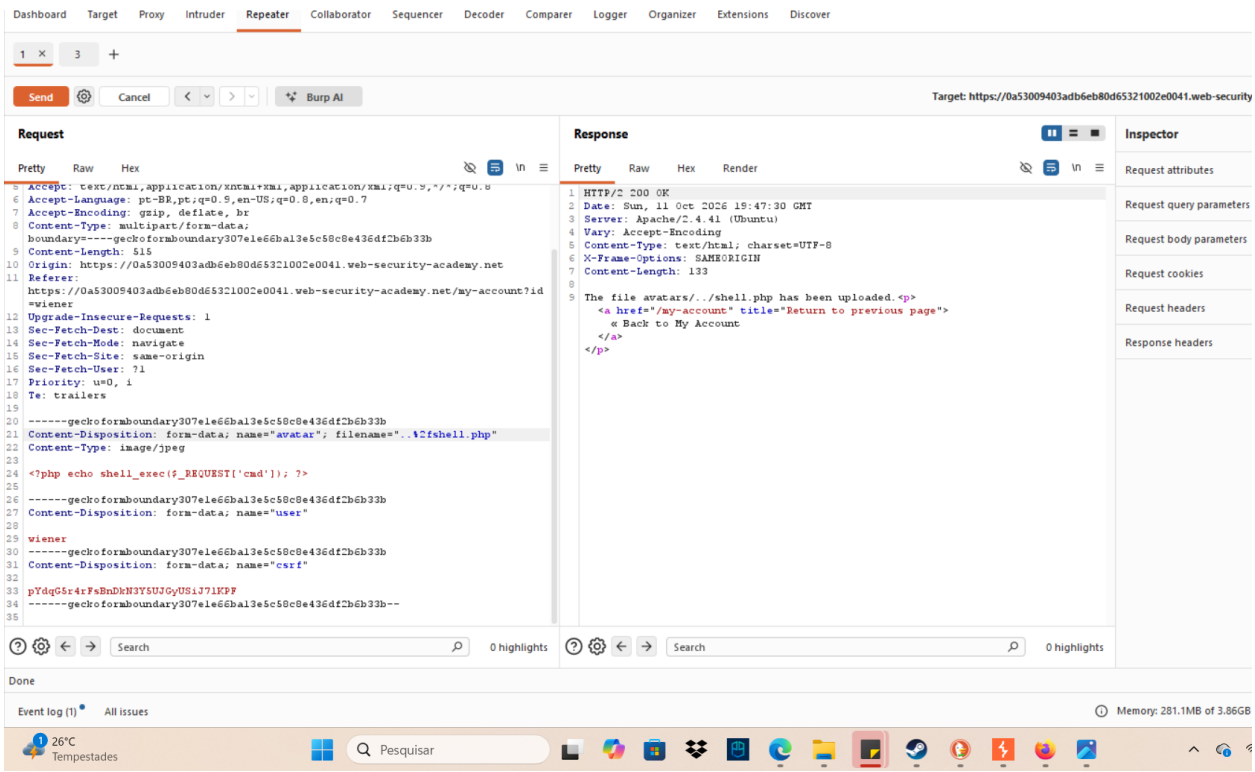


Repetindo a mesma técnica de bypass, agora com um arquivo PHP de teste simples (**<?php echo "HELLO WORLD"; ?>**) nomeado **..%2farquivo.php**, para confirmar se o PHP é de fato executado no diretório de destino.



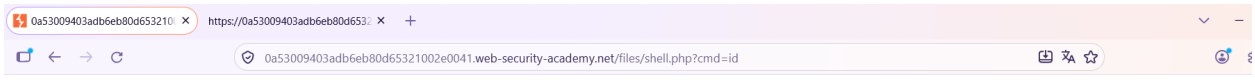


Acessando **/files/arquivo.php**, a página exibe o texto **HELLO WORLD** — prova definitiva de que o PHP é executado fora da pasta **avatars/**, validando toda a cadeia de bypass.



Com a execução de PHP confirmada, uma web shell funcional é enviada pelo mesmo caminho (**..%2fshell.php**), desta vez usando **shell_exec($_REQUEST['cmd'])** em vez de **system()**, já que esta última

função se mostrou bloqueada pelo ambiente em testes anteriores.



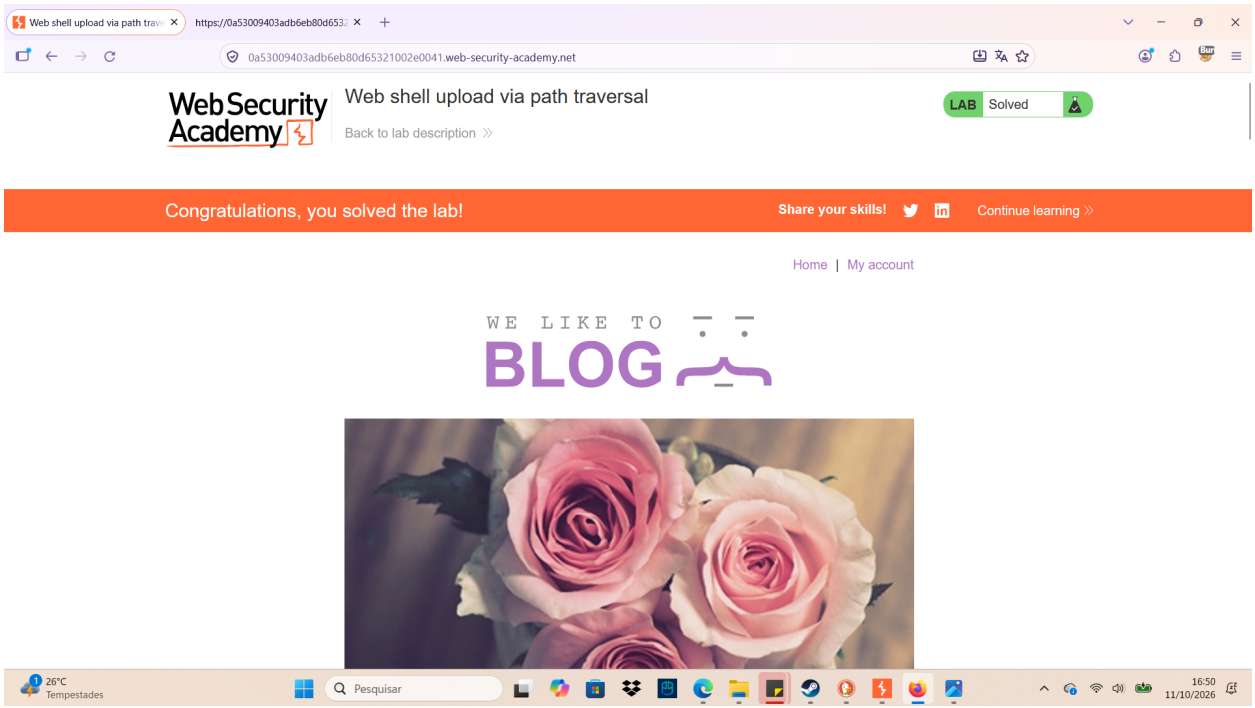


Execução de comando remoto bem-sucedida: acessando **/files/shell.php?cmd=id**, o servidor retorna **uid=12002(carlos) gid=12002(carlos) groups=12002(carlos)**, confirmando RCE completo através da web shell.





Usando a shell para navegar até o diretório da vítima e ler o arquivo-alvo (**cmd=cd /home;cd carlos;cat secret**), o servidor retorna o conteúdo do arquivo **/home/carlos/secret**.



Após submeter o valor do secret extraído no banner do laboratório, a aplicação confirma: **LAB Solved** — validando com sucesso toda a cadeia de exploração, do bypass de filtro de path traversal até a execução remota de comandos.